



Jason Ellison <infotek@gmail.com>

Seagate Black Armor security issue

Dan Kaminsky <dan@doxpara.com>
To: Jason Ellison <infotek@gmail.com>

Fri, Feb 5, 2010 at 10:08 PM

Looks like a first contact scenario, so there's no actual team set up to absorb these reports. So I'm trying to work my way to the actual product group that would be affected by the disclosure. See, large companies aren't one company, they're just these little fiefdoms. You hit some group that wouldn't actually be bothered by the vuln, and so they were useless. You have to get the the guy who pays the guy who wrote the bug. Then there's a chance.

I'm right now trying to route to that guy. We have a helpful Seagater.

On Fri, Feb 5, 2010 at 4:32 PM, Jason Ellison <infotek@gmail.com> wrote:

Dan,

What is the process... briefly.

Jason Ellison

On Fri, Feb 5, 2010 at 3:18 PM, Dan Kaminsky <dan@doxpara.com> wrote:

> Hello Jason,

>

> Just an update that the process has begun, and that hopefully sometime
> next week we'll have things routed appropriately.

>

> --Dan

>

>

> On Thu, Feb 4, 2010 at 10:00 PM, Dan Kaminsky <dan@doxpara.com> wrote:

>>

>> OK. I've got a path in, just please do not communicate with the useless
>> people :) Forward me any further mails you get.

>>

>> I think I will tell my contacts whatever you have, tomorrow. I expect
>> it'll take through next week to get this correctly routed (just because the
>> weekend is coming up).

>>

>> On Thu, Feb 4, 2010 at 9:56 PM, Jason Ellison <infotek@gmail.com> wrote:

>>>

>>> I can not write via the various web interfaces yet... But I think it
>>> is very possible. I'm now drinking wine so I will not mess with it
>>> anymore tonight :)

>>>

>>> On Thu, Feb 4, 2010 at 8:45 PM, Dan Kaminsky <dan@doxpara.com> wrote:

>>> > See if you can get code execution on this thing, it sounds like you're
>>> > close. (Physical access is always code execution, so serial doesn't
>>> > count
>>> > :))

>>> >

>>> > UPNP won't be relevant unless this thing plays as your NAT. (In which
>>> > case,
>>> > you'd ask for a port to be opened from the outside world.)

>>> >

>>> > Can you *write* via the admin interface?

>>> >

>>> > On Thu, Feb 4, 2010 at 9:44 PM, Jason Ellison <infotek@gmail.com>

>>> > wrote:
>>> >>
>>> >> Dan,
>>> >>
>>> >> I order a TTL level USB (TTL-232R-3V3) adapter which came in today.
>>> >> So I now have root access to the box via getty running on a serial
>>> >> port.
>>> >>
>>> >> Jason Ellison
>>> >> <http://www.jasonellison.net/>
>>> >>
>>> >> On Thu, Feb 4, 2010 at 8:40 PM, Jason Ellison <infotek@gmail.com>
>>> >> wrote:
>>> >> > Dan,
>>> >> >
>>> >> > You simply connect to the port. this is an embedded webserver for a
>>> >> > webinterface. And it loads plugins from a configured directory...
>>> >> > so
>>> >> > you could probably execute any payload by getting the password. To
>>> >> > top it off there is upnp software installed so you could most likely
>>> >> > get ports on consumer grade devices opened.
>>> >> >
>>> >> > Jason Ellison
>>> >> > <http://www.jasonellison.net/>
>>> >> >
>>> >> > On Thu, Feb 4, 2010 at 8:29 PM, Dan Kaminsky <dan@doxpara.com>
>>> >> > wrote:
>>> >> >> Assume there wasn't a firewall. I have very incomplete memories of
>>> >> >> DLNA/DAAP, do I need to do a broadcast to get some magic invite
>>> >> >> sequence, or
>>> >> >> can I just HTTP to 3689 to hit this admin stuff?
>>> >> >>
>>> >> >> On Thu, Feb 4, 2010 at 9:25 PM, Jason Ellison <infotek@gmail.com>
>>> >> >> wrote:
>>> >> >>>
>>> >> >>> It could work off lan but the administration interface is started
>>> >> >>> on
>>> >> >>> tcp/3689.
>>> >> >>>
>>> >> >>> Existing CVE's
>>> >> >>>
>>> >> >>> arbitrary execution
>>> >> >>> <http://www.securityfocus.com/bid/26310/info>
>>> >> >>>
>>> >> >>> DoS
>>> >> >>> <http://www.securityfocus.com/bid/26309>
>>> >> >>>
>>> >> >>> Jason Ellison
>>> >> >>> <http://www.jasonellison.net/>
>>> >> >>>
>>> >> >>> On Thu, Feb 4, 2010 at 8:05 PM, Dan Kaminsky <dan@doxpara.com>
>>> >> >>> wrote:
>>> >> >>> > So, this is anonymous arbitrary file read -- from the LAN, at
>>> >> >>> > least. Do
>>> >> >>> > you
>>> >> >>> > think this can work off-LAN as well?
>>> >> >>> >
>>> >> >>> > Is it possible there is a WebDAV endpoint at this location?
>>> >> >>> >
>>> >> >>> > Is it possible there is SQL injection off the Admin interface?
>>> >> >>> > That
>>> >> >>> > would,

>>> >> >>> > at minimum, obviate the need to MD5 crack.
>>> >> >>> >
>>> >> >>> > What are the severity of the CVE issues?
>>> >> >>> >
>>> >> >>> > I've got a path, I just want to leverage it as effectively as
>>> >> >>> > possible.
>>> >> >>> >
>>> >> >>> > On Thu, Feb 4, 2010 at 8:37 PM, Jason Ellison
>>> >> >>> > <infotek@gmail.com>
>>> >> >>> > wrote:
>>> >> >>> >>
>>> >> >>> >> Dan,
>>> >> >>> >>
>>> >> >>> >> Seagate Black Armor NAS.
>>> >> >>> >>
>>> >> >>> >> They used an open source DLNA/DAAP server. They have left a
>>> >> >>> >> administration panel open with a default username and password
>>> >> >>> >> which
>>> >> >>> >> is not modifiable. It seems that they were not even aware that
>>> >> >>> >> the
>>> >> >>> >> administration interface existed. The service runs as root.
>>> >> >>> >> You
>>> >> >>> >> can
>>> >> >>> >> attach to the service and configure it with a "webroot" of "/".
>>> >> >>> >> Grabbing any file from the system. Users that you added to the
>>> >> >>> >> system
>>> >> >>> >> are added to /etc/passwd with an md5 hash of the users
>>> >> >>> >> password.
>>> >> >>> >>
>>> >> >>> >> It's all very silly configuration mistakes... but has high
>>> >> >>> >> impact
>>> >> >>> >> if
>>> >> >>> >> you are local to the device. This device can be joined to a
>>> >> >>> >> domain
>>> >> >>> >> and is being sold as a Small/Med Business NAS.
>>> >> >>> >>
>>> >> >>> >> This device uses a version that has know security issues
>>> >> >>> >> already
>>> >> >>> >> documented in CVE.
>>> >> >>> >>
>>> >> >>> >> Jason Ellison
>>> >> >>> >> <http://www.jasonellison.net/>
>>> >> >>> >>
>>> >> >>> >> On Thu, Feb 4, 2010 at 5:56 PM, Dan Kaminsky <dan@doxpara.com>
>>> >> >>> >> wrote:
>>> >> >>> >> > Alright, I have a useful backchannel. Can you please provide
>>> >> >>> >> > me
>>> >> >>> >> > with
>>> >> >>> >> > a
>>> >> >>> >> > summary of the issue? I don't necessarily need to know how
>>> >> >>> >> > the
>>> >> >>> >> > attack
>>> >> >>> >> > works
>>> >> >>> >> > (though it would help), but I do need to know severity and
>>> >> >>> >> > attack
>>> >> >>> >> > scenarios.
>>> >> >>> >> >
>>> >> >>> >> >
>>> >> >>> >> >
>>> >> >>> >> > On Feb 4, 2010, at 6:03 PM, Jason Ellison <infotek@gmail.com>
>>> >> >>> >> > wrote:
>>> >> >>> >> >

>>> >> >>> >> >> Dan,
>>> >> >>> >> >>
>>> >> >>> >> >> Could you assist or advise on the proper channel to contact
>>> >> >>> >> >> Seagate
>>> >> >>> >> >> about a security issue with their Black Armor 440 NAS
>>> >> >>> >> >> product...
>>> >> >>> >> >> I've
>>> >> >>> >> >> been stuck dealing with :
>>> >> >>> >> >>
>>> >> >>> >> >> This guy noticed the email I wrote on fulldisclosure when it
>>> >> >>> >> >> appeared
>>> >> >>> >> >> in on twitter. I think they pay him to search Social Media
>>> >> >>> >> >> sites
>>> >> >>> >> >> for
>>> >> >>> >> >> the word "Seagate".
>>> >> >>> >> >>
>>> >> >>> >> >> Rich Harris - Senior Manager, Social Media
>>> >> >>> >> >> Seagate Technology, LLC
>>> >> >>> >> >> 831.439.5424
>>> >> >>> >> >> rich.harris@seagate.com
>>> >> >>> >> >>
>>> >> >>> >> >> This is the guy that was Rich Harris put in touch with me,
>>> >> >>> >> >> who
>>> >> >>> >> >> normally deals with mad customers and has the power to waive
>>> >> >>> >> >> shipping.
>>> >> >>> >> >>
>>> >> >>> >> >> Bryce Stoops
>>> >> >>> >> >> Corporate Escalations
>>> >> >>> >> >> 405.324.3257
>>> >> >>> >> >> bryce.stoops@seagate.com
>>> >> >>> >> >>
>>> >> >>> >> >> I told Bryce Stoops that I intended to report this publicly
>>> >> >>> >> >> after a
>>> >> >>> >> >> reasonable time period, following Responsible Disclosure
>>> >> >>> >> >> Guidelines.
>>> >> >>> >> >> And now the PR guy is calling and emailing me after hours to
>>> >> >>> >> >> tell me
>>> >> >>> >> >> that I should not mention anything public.
>>> >> >>> >> >>
>>> >> >>> >> >> Nathan Papadopoulos
>>> >> >>> >> >> Senior Manager
>>> >> >>> >> >> Seagate Corporate Communications
>>> >> >>> >> >> 100 Mathilda Place
>>> >> >>> >> >> Sunnyvale, CA 94086
>>> >> >>> >> >> v: (408) 328. 2167
>>> >> >>> >> >> m:(415) 420.3152
>>> >> >>> >> >> f: (408) 328.2186
>>> >> >>> >> >>
>>> >> >>> >> >> Not once has an Engineer or Security person communicated
>>> >> >>> >> >> with
>>> >> >>> >> >> me. I
>>> >> >>> >> >> don't think it is getting to the correct people.
>>> >> >>> >> >>
>>> >> >>> >> >> Jason Ellison
>>> >> >>> >> >>
>>> >> >>> >> >> On Mon, Feb 1, 2010 at 12:44 PM, Dan Kaminsky
>>> >> >>> >> >> <dan@doxpara.com>
>>> >> >>> >> >> wrote:
>>> >> >>> >> >>
>>> >> >>> >>> >> Let me know if one does not appear. I will happily assist.
>>> >> >>> >>> >>
>>> >> >>> >>> >>

```
>>> >> >>> >> >>>
>>> >> >>> >> >>> On Feb 1, 2010, at 1:32 PM, Jason Ellison
>>> >> >>> >> >>> <infotek@gmail.com>
>>> >> >>> >> >>> wrote:
>>> >> >>> >> >>>
>>> >> >>> >> >>>> List,
>>> >> >>> >> >>>>
>>> >> >>> >> >>>> I found a security issue on a Seagate Black Armor 440
>>> >> >>> >> >>>> NAS.
>>> >> >>> >> >>>> I'm
>>> >> >>> >> >>>> looking for a PoC at Seagate to discuss this issue.
>>> >> >>> >> >>>>
>>> >> >>> >> >>>> Jason Ellison
>>> >> >>> >> >>>>
>>> >> >>> >> >>>>
>>> >> >>> >> >>>> Full-Disclosure - We believe in it.
>>> >> >>> >> >>>> Charter:
>>> >> >>> >> >>>> http://lists.grok.org.uk/full-disclosure-charter.html
>>> >> >>> >> >>>> Hosted and sponsored by Secunia - http://secunia.com/
>>> >> >>> >> >>>>
>>> >> >>> >> >>>>
>>> >> >>> >
>>> >> >>> >
>>> >> >>
>>> >> >>
>>> >> >>
>>> >> >
>>> >
>>
>
>
```